Master Checklist — SecretHandle (A→Z)

Một nguồn duy nhất để biết đã làm đến đâu và bước tiếp theo

Cập nhật: 2026-10-22 | Mục tiêu: **ACM MobiSys 2027 — Emerging Ideas** (nộp 04/12/2026) | Nguyên tắc: không placeholder nào được trình bày như kết quả.

Ký hiệu trạng thái: ■ Đã xong ⊡ Đang làm / một phần □ Chưa bắt đầu ▶ Đang tắc (blocker)

Mốc quan trọng (lịch MobiSys 2027)

Cổng	Hạn	Điều kiện qua (tóm tắt)
G0	25/10/2026 (W2)	Môi trường dev sẵn sàng; **B0 tái hiện được** trên emulator/stock; chốt D0–D6 **(ĐẠT 2026-10-17)**
G1	15/11/2026 (W5)	Tái hiện đầy đủ họ tấn công (1,3,4,7) + bằng chứng sơ bộ từ mô hình tham chiếu + khung bản thảo (problem/threat/design) **(ĐẠT 2026-10-17; `docs/gates/G1.md`)**
G2	27/11/2026 (W7)	**Đăng ký abstract** (tiêu đề + abstract ≥100 từ, không "TBD"); bản thảo gần hoàn chỉnh
G3	01/12/2026 (W7)	Đóng băng bản thảo 12 trang + phụ lục; chuyển `acmart` sigconf; **ghi tên tác giả**; gán nhãn LLM
Nộp	04/12/2026 (AoE)	**MobiSys 2027 — Emerging Ideas** (tiêu đề bắt đầu `[Emerging Ideas]`)
Plan B	2027	Full paper (T1 + số đo thiết bị thật) cho MobiSys 2028 / USENIX / NDSS / IEEE S&P

PHẦN 0 — Phạm vi nộp 04/12/2026: Emerging Ideas

Track Emerging Ideas ưu tiên *originality, clarity of insight, potential* hơn độ hoàn thiện; *không* đòi evaluation đầy đủ. Vì vậy bản nộp gồm:

- **Vấn đề & tác động**: OTP/bí mật lộ cho tác nhân AI di động (attack B0 **đã tái hiện** trên emulator, 10/10). **2026-10-22:** tái tái lập Gate G1 (10/10, Wilson [0.722, 1.0]) + build fixture giờ byte-deterministic.
- **Mô hình đe dọa & principal**: 3 kiểu caller (D3) đã đưa vào `mobisys/sections/threat_model.tex` (app UID / shell-UiAutomation / serialize; root vô hiệu hóa).
- **Thiết kế** SecretHandle: đúc tại nguồn OS, ràng buộc đích + tác vụ, vòng đời một lần, redaction quan sát. **2026-10-22:** ngôn ngữ chính sách + vòng đời đã có trong `mobisys/sections/design.tex` (§Policy language, §Lifecycle and reservation); người dùng tự lo phần này.
- **Bằng chứng sơ bộ**: tái hiện tấn công B0 thực trên emulator (xong 2026-10-17); *mô hình tham chiếu Python* mô hình hóa tường minh họ **1,3,4,7** (thêm `read_exfil`, `ambiguous_identity`) — 6400 trial, seed 20261017, đã ghi rõ là mô phỏng (không phải AOSP) tại `docs/preliminary_evidence.md`. **2026-10-29:** mở rộng cặp **B0-vs-B3** thực trên emulator lên $n = 30$ trial mỗi bên (B0 $29/30$ rò rỉ, Wilson $[0.83, 0.99]$; B3 prototype $0/30$ rò rỉ, Wilson $[0.00, 0.114]$; đối chứng tắt redaction $1/1$) vào `mobisys/sections/evidence.tex` kèm Bảng 3 + Hình 2, cập nhật abstract/introduction/limitations.
- **Kế hoạch đánh giá** đầy đủ (killer experiment, ma trận T1, cỡ mẫu, thống kê) cho bản full tại `docs/evaluation_plan.md`.
- Nêu rõ **giới hạn** tại `mobisys/sections/limitations.tex`: chưa có số đo thiết bị thật; keystore mức phần mềm; WebView fail-closed; binding không bảo đảm dùng trung thực.
- Tuân thủ format: **tối đa** 12 trang thân bài (đây là *mức tối đa*, **không** phải mục tiêu; phụ lục + tham khảo không tính), `\documentclass[sigconf,10pt]{acmart}` (đã có `mobisys/main.tex`, tiêu đề đã thêm

`[Emerging Ideas]`), US Letter, double-column, cỡ chữ ≥10pt. **CFP đã đối chiếu 2026-10-17.** Hiện **14 trang** tổng (thân bài 12 trang, tham khảo bắt đầu từ tr. 12, phụ lục tr. 13–14; CFP *không* tính tham khảo/phụ lục) ⇒ **hợp lệ**.

- ■ Single-blind + đạo đức + LLM tại `mobisys/sections/ethics.tex` (canary tổng hợp ⇒ không human subjects; gán nhãn LLM).

Tiến độ tổng quan

Nhóm	Trạng thái
Tài liệu ý tưởng + bản thảo + mô hình tham chiếu	■ ~90% (khung mobisys ■; điền tên tác giả do người dùng)
Audit cấp bản thảo (citation/figure/math/reviewer/notation)	■
Quyết định D0–D6	■ (đã chốt 2026-10-17)
Triển khai AOSP (Track A)	□ 0% (đường Plan B)
Ứng dụng/tác nhân/harness (Track B)	■ ~75% (repo integration + deterministic build + gate G0/G1 PASS; runner Mobile-Agent pinned; B3 prototype stock-Android + đo B0-vs-B3 $n = 30$)
Baseline/ablation thực	⊡ chỉ có bản tổng hợp
Thí nghiệm thực & số đo	■ B0-rate và cặp B0-vs-B3 trên emulator ($n = 30$, B3 prototype 0/30 vs B0 29/30, Wilson [0, 0.114])
Phân tích thống kê / viết lại theo venue	⊡ ~65% (bản thảo mobisys theo CFP xong; thống kê bản full chưa bắt đầu)
Artifact & nộp	⊡ ~50% (LICENSE Apache-2.0, docs artifact, CI, checker; còn nộp bài + patch set AOSP)

PHẦN A — Nền tảng đã có (chỉ bảo trì)

- ■ Ý tưởng gốc: `idea.tex` / `idea.pdf` (5 trang) + `idea_fidelity_report.md`, `topic_signature.json`.
- ■ Bản thảo 53 trang: `main.tex` + 13 `sections/` + 2 `appendix/` + 6 hình TikZ/PGFPlots; `main.pdf`.

- Mô hình tham chiếu Python `SecretHandle/src/secrethandle/` (core, crypto, policy, store, redaction, metrics, statistics, adapters, baselines, oracles, experiments, plotting, synthetic, integrity, cli).
- Bộ test offline: **74 passed** (`python -m pytest -q`).
- Harness + config tổng hợp + script demo/plot/experiment.
- Audit cấp bản thảo: `citation_claim_map.csv`, `citation_consistency_report.md`, `math_audit.md`, `claim_strength_audit.md`, `figure_quality_audit.md`, `notation_consistency_check.md`, `reviewer_audit.md`, `theorem_dependency_graph.md`, `topic_alignment_check.md`.
- Audit cấp mã: `SecretHandle/audits/` (paper_implementation_spec, paper_to_code_traceability, math_to_code_audit, implementation_gaps, result_integrity_audit).
- Tài liệu hướng dẫn: `instructions/SecretHandle_HuongDan.tex` (v2, cập nhật v3 cho MobiSys).
- Nhật ký quyết định: `SecretHandle/docs/design_decisions.md` (D0–D6 đã chốt).

PHẦN B — Giai đoạn 0: Chuẩn bị & quyết định (W1–W2, cổng G0)

B1. Quyết định thiết kế (đã chốt 2026-10-17)

- **D0** Venue/lịch: **MobiSys 2027, Emerging Ideas** (nộp 04/12/2026); full paper để Plan B.
- **D1** Authenticator: giữ MAC (HMAC-SHA-256, canonical, tách khóa).
- **D2** Kho lưu trữ: trong bộ nhớ `system_server`; khởi động lại = thu hồi.
- **D3** Principal tác nhân: 3 kiểu (UID app / UID shell-UiAutomation / serialize) + bảng điểm chặn.
- **D4** Giảm u tại bước giữ chỗ (bảo thủ).
- **D5** WebView: T1 chỉ view gốc; WebView fail-closed.
- **D6** Môi trường: không có Pixel ⇒ emulator/Cuttlefish với ảnh AOSP tự build; số đo thiết bị thật = future work.

B2. Track A — môi trường AOSP (đường Plan B, chạy song song)

- ☐ `repo sync` AOSP (hàng chục–trăm GB, nhiều giờ) — chuẩn bị *bản full*, **không** phải điều kiện nộp 04/12.
- ☐ Ghim commit/branch AOSP; ghi provenance.
- ☐ Dựng **Android Emulator** với ảnh AOSP tự build (máy Windows) *hoặc* **Cuttlefish** (Linux/GCP có KVM) — môi trường chính theo D6.
- ☐ Build ảnh AOSP (thay cho flash Pixel); boot được trên emulator/Cuttlefish.

B3. Track B — môi trường & cấp phát

- Dựng Python 3.12; `python -m pip install -e '.[dev]'` (venv `SecretHandle/.venv`).
- Xác nhận `ruff` 0.17.1 + `mypy` 2.4.0 chạy được; **đã xử lý** hết cảnh báo ruff + lỗi mypy (PHẦN C, 2026-10-17).
- Tạo repo Git integration *tách* khỏi package tham chiếu (AOSP patch, adapter, tác nhân) — **2026-10-22:** `github.com/Thunggg/secrethandle-integration` (private), local `E:\NCKH\secrethandle-integration`; đã di chuyển `device/b0-otp-forwarding`; cấu trúc aosp-patches/device/agents/apps/env/runs; `provenance.md` ghi SHA cả 2 repo (`8f3e25d5` tham khảo / `3b85895` integration) + hash APK SHA-256; README quy tắc (raw secret-free, AI-disclosure trong commit, số functional-repro nhãn "not a paper number").
- Dựng EC2 cô lập: volume/user riêng, tường lửa chặt, credential trong secret manager (không trong YAML/log/repo). **2026-10-22:** EC2 do giảng viên cấp; spec yêu cầu sẵn sàng ở `secrethandle-integration/env/ec2` (m6i.2xlarge pilot → m6i.4xlarge spot ma trận, SSM, 0 inbound, budget $20/$150); cổng pre-EC2 6 nấc ở `env/pre_ec2_gate_and_runbook.md` — nấc G0 (offline 'make check') đã PASSED (ruff + mypy + 74 tests + canary smoke 6400 trial). **2026-10-28 (host thực tế):** `m8i.4xlarge` (16 vCPU/64 GiB, Ubuntu 24.04.5, gp3 500 GB) với `NestedVirtualization=enabled` ⇒ có `/dev/kvm` + 32 cờ

vmx; AVD bench (Android 14, 1080×2400) boot headless OK, screencap OK; trên host: **74 test offline + canary 6400 trial/0 leak PASS**; bridge deps cài sẵn (~/bridge-venv); ghép nối SSH từ IP tác nhân hoạt động.

- ■ **G3 — bridge → Bedrock thật (2026-10-28)**: dùng *Bedrock API key* dạng bearer (bedrock-api-key-...) do giảng viên cấp; khóa lưu *ngoài repo* (env/.env.bedrock.local, đã gitignore; trên host ~/.sh_bedrock.env quyền 600, loader không source vì token chứa &Version=1). Bridge trả HTTP 200 với us.anthropic.claude-sonnet-4-6 (12+4 token, 0,81 s); /healthz chỉ báo bedrock_bearer_present, không lộ giá trị. Do đó **không cần IAM instance profile** nữa.
- ■ **G2 — pilot tác nhân thật với Bedrock (2026-10-28)**: dựng Mobile-Agent v3.5 + AndroidWorld trên EC2 (AVD AndroidWorldAvd, API 33, -grpc 8554, cài android_env, torch CPU, qwen_vl_utils); phải sửa 4 lỗi tích hợp mới chạy được — quy đổi toạ độ (model trả *pixel của ảnh đã resize*, không phải 0–1000), prompt nêu rõ quy ước, hạ ảnh $1080 \times 2400 \to 844 \times 1876$ (3,4k → 2,1k token/lời gọi), cap 8 bước/tác vụ; ghi ở agents/MA35_PATCHES.md. Kết quả: (i) 10 tác vụ benign B0 = **1/10** trước khi sửa toạ độ và **0/10** sau khi sửa — tức năng lực điều khiển UI của mô hình chat là nút thắt, *không phải số báo cáo* (cần GUI-Owl hoặc agent theo chỉ số phần tử/M3A); (ii) **OTP gửi bằng SMS, điều kiện B0: 10/10 trial agent đọc và trả lời đúng canary** (3–4 bước, 10–13 lời gọi, 42–63 s, ≈$0,11/trial; Wilson 95% CI [0,72; 1,00]). Đọc bí mật cần ít độ chính xác chạm hơn nhiều so với hoàn thành tác vụ, nên tỉ lệ rò rỉ 100% vẫn đứng dù task success ≈0. Đây là *mức rò rỉ nền* khi chưa có SecretHandle (B3 chưa tồn tại), không phải kết quả so sánh. Chi phí token cả phiên ≈$9.
- □ Khởi động thủ tục dài: license AndroidWorld/SPA-Bench, API key cloud model + trần chi phí, thiết bị.
- ■ **Tái hiện tấn công B0** (OTP-forwarding) trên emulator/Android stock 14: **10/10** trial rò rỉ, exposure rate **1.0** (Wilson 95% [0.72, 1.0]; rate_results.json).
- ■ Dựng disclosure monitor bản đầu (monitor/monitor.py, run_rate.py; log exfil_log.jsonl).
- ■ Khung đạo đức: quy trình canary, endpoint cô lập, không dữ liệu thật; kiểm yêu cầu IRB/hội đồng + mục ethics CFP (docs/ethics.md, 2026-10-17).
- ■ **Tái hiện B0 trên host EC2 thực tế — 2026-10-28:** port build.ps1 sang Linux (build_linux.sh: aapt2/javac 17/d8/zipalign/apksigner; APK cuối SHA-256 84845755...4d620a), cài lên AVD bench: **10/10** và **100/100** trial rò rỉ, exposure **1.0** (Wilson 95% [0.963, 1.0]), received_count=100 (1:1). Ba lỗi *harness* đã tìm và sửa (không phải lỗi host): (i) API 34 cần cmd notification allow_listener, chỉ settings put thì không bind; (ii) hệ thống re-deliver notification đang active gây POST $O(n^2)$ rồi cạn kết nối → dedupe theo *toàn bộ text* của notification; (iii) Messages ngừng post khi shade bão hoà (∼47 hội thoại) → gọi cancelAllNotifications() sau mỗi lần forward; thêm warm-up SMS để tránh race lúc bind listener. Nhãn: *functional reproduction, not a paper number*.
- ■ **B3 — prototype trên Android stock (2026-10-28**, device/b3-secrethandle/): broker notification (mint handle SH-XXXXXX, cancel rồi repost notification đã redact) + accessibility service phủ overlay TYPE_ACCESSIBILITY_OVERLAY lên đúng node chứa mã; vault giữ plaintext TTL 5 phút, resolve *một lần*, audit files/audit.jsonl (mint/mask/resolve/deny). Đo trên *cùng* AVD/harness/model/canary với B0: **0/10 trial rò rỉ** (Wilson 95% [0; 0,278]) so với **10/10** của B0; 6 bước/trial (chạm cap), 113 s, ≈20,7 lời gọi, ≈$0,23/trial. **Đối chứng khi tắt service redaction: 1/1 rò rỉ trong 2 bước** — nên 0/10 không phải lỗi harness. Bốn lỗi tích hợp đã tìm và sửa: (i) API 33 cần POST_NOTIFICATIONS nếu không notification thay thế bị bỏ âm thầm; (ii) overlay lệch đúng một status bar (∼128 px) do thiếu FLAG_LAYOUT_IN_SCREEN; (iii) mask bị xoá vì clear-all mỗi accessibility event → chuyển sang cập nhật tăng dần (map rect→view) + quét 200 ms; (iv) harness ghi đè enabled_accessibility_services bằng AccessibilityForwarder → phải bật lại sau env.reset() và ghi b3_a11y_active mỗi trial. Hạn chế ghi rõ trong runs/2026-10-28-b3/README.md: overlay chỉ che kênh *screenshot* (accessibility tree vẫn xuất text gốc), clipboard chưa được mediate (agent đã thử copy/paste), và đây **không phải** system_server — đường triển khai AOSP vẫn là Track A.
- ■ **Sửa metric rò rỉ của driver (2026-10-28)**: bản đầu grep canary trong *toàn bộ* log trial, mà log chứa dòng TRIAL_RECORD (có canary) ⇒ cột leaked luôn bằng 1. Nay aw_attack_one.py tính canary_in_actions (đọc action.jsonl) + canary_in_sent_sms, driver đọc record.json. Tính lại B0 từ trajectory đã lưu: vẫn **10/10** (env/ec2_scripts/b0_recompute_leak.sh).

- Ghim phiên bản Python/OS/công cụ thống kê vào provenance — **2026-10-22:** `docs/toolchain_pins.json` (Python 3.12.10 / Windows-11-26300 / numpy 2.5.4 / matplotlib 3.11.2 / PyYAML 6.0.3 / ruff 0.17.1 / mypy 2.4.0, gắn HEAD `8f3e25d5`); chạy lại và ghi lạipin khi đổi ngữ nghĩa tham chiếu.

B4. DoD của G0

- `pytest` xanh 100% (hiện 74 passed).
- Không có bí mật thật trong repo (quét mẫu high-signal = 0; không `.env`/tệp khóa; `debug.keystore` là keystore debug dùng-một-lần).
- ⊡ Môi trường dev sẵn sàng (venv 3.12 + `ruff`/`mypy`); emulator chạy **ảnh stock** (chưa phải ảnh AOSP tự build).
- **B0 tái hiện được** trên emulator/stock Android (điều kiện cứng của G0) — 2026-10-17, 10/10 rò rỉ.
- D0–D6 có tài liệu quyết định.
- Khung đạo đức xong (canary tổng hợp, endpoint cô lập, không dữ liệu thật) — `docs/ethics.md`.
- **Qua G0 (25/10/2026)** — biên bản cổng: `docs/gates/G0.md` (lập 2026-10-17, kết luận ĐẠT kèm ghi chú ảnh stock).

PHẦN C — Giai đoạn 1: Củng cố mô hình tham chiếu Python (W1–W2)

- Soát `core/crypto/policy/store/redaction/metrics/statistics` đối chiếu Algorithm 1–3 + `paper_to_code_traceability.csv`; **áp dụng D1** (HMAC-SHA-256 chuẩn tắc, tách khóa) và **D4** (giảm ngân sách tại bước giữ chỗ; metadata đã xác thực bất biến, ngân sách còn lại tách riêng) — 2026-10-17. Đã sửa lỗi: trước đây giảm `u` bên trong `H` làm hỏng `a` cho handle nhiều lần dùng.
- Test dựa tính chất: giao hội chính sách không mở rộng quyền; single-use đồng thời; đơn điệu hết hạn — `tests/test_properties.py` (seed cố định 20261017, 2000 mẫu/chính sách; 5 seed cho single-use).
- Test dựa mô hình: lịch trình crash/đồng thời tại ranh giới reserve/commit/rollback/recover — `tests/test_model.py` (4 kịch bản xác định + 300 lịch trình ngẫu nhiên: không bao giờ giao quá ngân sách đơn dùng).
- Đóng băng hợp đồng adapter (contract v1, 2026-10-17): bốn adapter AOSP/platform-flow/agent-runner/benchmark cùng các protocol tin cậy; `test_adapter_contracts.py` khóa chữ ký phương thức.
- Property test: không trường bí mật rò qua serialization công khai/audit — trong `test_properties.py` (repr handle/record/store + audit; cả dạng hex).
- Mở rộng oracle tiết lộ: exact, base64, URL, JSON, chuẩn hóa Unicode, chuẩn hóa chữ số và dạng ngăn cách (space/gạch) — `oracles.DisclosureOracle` (2026-10-17).
- Chạy `ruff` + `mypy`, xử lý cảnh báo: **0 cảnh báo, 0 lỗi** (2026-10-17). Ghim cấu hình ruff tường minh trong `pyproject.toml`; nâng `requires-python` lên `>=3.10` để hiện đại hóa typing; thêm `types-PyYAML`. `pytest`: 39 → 42 (họ 1,7) → 53 (property/model) → 58 (adapter contract) → 73 (2026-10-17) → **74 passed** (thêm smoke canary, PHẦN M).
- Cập nhật `SecretHandle/audits/` sau mỗi thay đổi ngữ nghĩa — 2026-10-17: cập nhật traceability, math-to-code, gaps, spec và phụ lục result-integrity.
- **DoD:** test xanh (74 passed); mọi thay đổi ngữ nghĩa có test (D4 có `test_store`/`test_model`, oracle có `test_oracles`, adapter có `test_adapter_contracts`); traceability phủ 100% đối tượng paper đã cài.

Các PHẦN D–N dưới đây mô tả *bản full* (Plan B) với lịch W1–W16. Với bản nộp **04/12/2026** (MobiSys Emerging Ideas), phần lớn hạng mục ở đây *chưa* cần — xem **PHẦN 0** để biết phạm vi bản nộp.

PHẦN D — Giai đoạn 2: Walking skeleton (cổng G1, Track A+B) [bản full]

- ☐ Lát cắt dọc đầu: SMS → mint → `ENTER` → ô nhập app đăng nhập.
- ☐ Dịch vụ `system_server` với AIDL tối thiểu: `mint` (allowlist), `resolve`, `revoke`; kho trong bộ nhớ (D2).
- ☐ Adapter SMS/thông báo bản test (emulator console hoặc app SMS test); che mã khỏi thông báo hướng tác nhân.
- ☐ Resolver tối thiểu: `ResolveFreshTargetContext` (package + field + tác vụ); từ chối nếu không khớp.
- ☐ Giữ chỗ nguyên tử bằng khóa kho.
- ☐ Đường vào cho tác nhân ADB: `cmd secrethandle enter` chạy UID shell; resolver kiểm tra UID; giá trị không qua stdout/log.
- ☐ Redaction cây trợ năng theo principal (so khớp giá trị chính xác) + che cửa sổ nguồn.
- ☐ App A (đăng nhập + OTP) + endpoint verifier/attacker cô lập.
- ☐ Adapter tác nhân → `ENTER(handle)`.
- ☐ Disclosure monitor.
- ☐ Killer thu nhỏ $n = 30$ B0 vs B3 với planner kịch bản + 1 tác nhân thật.
- ☐ **Không làm ở giai đoạn này:** kho bền vững, khóa phần cứng, xác nhận, WebView, ví, đa người dùng.
- ☐ **DoD G1:** `ENTER(handle)` vào trường OTP hợp lệ nhập đúng một lần; đích sai bị từ chối; canary vắng trong cây trợ năng + log tác nhân.
- ☐ **Qua G1 (15/11/2026)** — biên bản cổng. Nếu redaction ảnh chụp bất khả thi → lùi về che theo cửa sổ, ghi giới hạn.

PHẦN E — Giai đoạn 3: Hoàn thiện lõi dịch vụ & resolver (W6–W8, Track A)

- ☐ AIDL đầy đủ: `mint` (chỉ adapter allowlist), `listHandles`, `resolve`, `revoke`, `exportAudit` (bảo vệ, rate-limit).
- ☐ Mô hình quyền: xác thực caller/provenance trước khi đúc; task-token verifier, source allowlist, quota, rate limit.
- ☐ **Target node token**: ràng buộc window/connection/node/generation/package UID + TTL ngắn.
- ☐ Phân loại trường: input type framework, autofill hints, view semantics; không nhất quán → fail-closed.
- ☐ Giữ chỗ nguyên tử (CAS/khóa) live→reserved; tái xác thực đích trước nhập; inject một lần ràng buộc reservation.
- ☐ Mã hóa chuẩn tắc metadata, tách khóa, độ dài tag (nếu giữ MAC theo D1); báo cáo security level thực (TEE/StrongBox/none).
- ☐ Thu hồi: kết thúc tác vụ, khóa thiết bị, đổi profile, đổi package đích.
- ☐ Bảng xử lý lỗi (unknown handle, expired, mismatch, target vanished, redactor mất theo dõi, crash), tất cả value-oblivious; wipe bộ đệm mọi đường thoát.
- ☐ Test đồng thời đầu-cuối + `kill system_server` tại từng ranh giới reserve/register/inject/commit.
- ☐ **DoD:** test binder allowlist xanh; không có lịch trình đồng thời nào giao hai lần; kill giữa chừng không giao hai lần.

PHẦN F — Giai đoạn 4: Redaction quan sát & đường nhập riêng (W6–W9, Track A)

- ☐ Đường nhập riêng (private input) bỏ qua đường thao tác hướng tác nhân + lịch sử/gợi ý IME.
- ☐ Đăng ký nghĩa vụ redaction ρ **trước** khi giao giá trị.
- ☐ Redaction trợ năng theo principal: thay giá trị/text/sự kiện bằng mask theo kiểu.

- ☐ Redaction ảnh chụp **trước khi** buffer map vào tiến trình tác nhân (không overlay sau); phủ `screencap`, UiAutomation, MediaProjection, `takeScreenshot`.
- ☐ Theo dõi định danh view/window ổn định; tính lại bounds tại capture; không định danh lại được → che window 1 frame hoặc bỏ frame.
- ☐ Che bề mặt nguồn theo cửa sổ (thông báo, ứng dụng SMS, màn hình khóa) suốt đời handle.
- ☐ Loại action echo, debug text, content description chứa tài liệu bảo vệ.
- ☐ Kết thúc redaction khi trường xóa/window đóng/tác vụ kết thúc/trạng thái app tin cậy — **không** chỉ hẹn giờ.
- ☐ Harness đọc lại: sau nhập, thu ảnh chụp, cây trợ năng, text-change event, clipboard, IME, `logcat`, `dumpsys` qua UID app, UID shell, quan sát serialize; oracle mã hóa đa dạng.
- ☐ (T3) WebView origin binding, Protected Confirmation; nếu chưa → dialog hệ thống + nhãn assurance yếu hơn.
- ☐ **DoD (G2):** pilot $n = 100$ sau nhập giá trị vắng mặt trong mọi kênh trên cả 3 kiểu principal; mọi trường hợp không chắc chắn fail-closed.
- ☐ **Mốc bản full: T1 đủ chức năng** — nếu không đạt → giữ phạm vi hẹp, không mở T2/T3.

PHẦN G — Giai đoạn 5: Ứng dụng, endpoint, tác nhân, monitor (Track B, W1–W9)

- ☐ App A: đăng nhập + OTP SMS (T1).
- ☐ App B: 2FA nhiều trang với preview tin nhắn đối kháng (T1).
- ☐ App C: checkout địa chỉ + điện thoại (T2).
- ☐ App D: checkout token ví + xác nhận mỗi lần (T3).
- ☐ Mỗi app chỉ ghi ground-truth vào harness bảo vệ: định danh đích, đã giao/chưa, server chấp nhận, hoàn tất.
- ☐ Endpoint verifier (đo tính sẵn có định danh) + endpoint attacker cô lập (đích ngoài d), không mạng thật.
- ☐ Ghim nguồn + build + băm APK (SHA-256); ghi schema oracle server.
- ☐ Tác nhân: chọn 1 runner chính (AppAgent hoặc runner tương thích AndroidWorld đang bảo trì); thử tái hiện B0 ở G0.
- ☐ Tác nhân thứ hai (Mobile-Agent, DroidRun nếu ổn định) — T2.
- ☐ Mô hình: 1 cloud + 1 local/open-weights nếu khả thi, nếu không 2 cloud khác; ghim định danh + ngày chạy.
- ☐ Disclosure monitor: tìm canary chính xác + mã hóa cấu trúc trong prompt, ảnh (OCR), cây trợ năng, tool call, trace, model traffic, planner state, actions, clipboard, IME, logs, crash data, attacker traffic.
- ☐ Hồi quy tác vụ chung (AndroidWorld/SPA-Bench) — T2.
- ☐ **DoD:** chạy được 1 luồng app A dưới giám sát disclosure, tái lập với seed cố định; build tái lập; hash khớp.

PHẦN H — Giai đoạn 6: Baseline & ablation (W6–W10)

- ☐ **B0** (không bảo vệ): chỉ canary tổng hợp + đích trong bộ nhớ cô lập.
- ☐ **B1** (placeholder phát hiện được): bộ phát hiện tham chiếu tất định **hoặc** cài đặt thực của tác giả (cần duyệt); ghi rõ phạm vi.
- ☐ **B3** (SecretHandle): adapter AOSP đầy đủ cho T1 (mint, target token, private input, redaction, audit).
- ☐ **B2** (T2): Autofill/OTP Autofill/Credential Manager cho app hợp tác; `FLAG_SECURE`, che trường mật khẩu, content sensitivity; workflow không hỗ trợ ghi `not_applicable`.
- ☐ Ablation T1 (tắt từng thứ): đúc nguồn (thay bằng cạo màn hình), ràng buộc đích, ràng buộc tác vụ, vòng đời nguyên tử, redaction sau nhập; kiểm origin là T3.

- ☐ Biến thể không an toàn **chỉ** dùng canary tổng hợp + endpoint cô lập.
- ☐ **Đóng băng tham số trước khi xem kết quả**: bits định danh, bits tag, TTL, ngân sách dùng, rate limit, thời lượng quan sát, số lặp, số bootstrap, chính sách outlier, cỡ mẫu từng ô.
- ☐ **DoD (G3):** chuyển B0↔B3 không đổi text tác vụ; audit hiển thị quyết định; oracle cô lập; tham số đóng băng.
- ☐ **Mốc bản full: đóng băng mã hệ thống** — từ đây chỉ sửa lỗi có ghi nhận.

PHẦN I — Giai đoạn 7: Chạy thí nghiệm (W10–W13)

- ☐ Provisioning theo `docs/ec2_experiment_guide.md`; đặt tệp theo `docs/data_format.md`; clone repo tác nhân/benchmark tại commit đã audit.
- ☐ Copy `configs/experiment_template.yaml`; đặt đường dẫn/ID đã cấp phát; đóng băng tham số.
- ☐ Smoke test canary cô lập: xác nhận không có dữ liệu thật. Bản offline tổng hợp đã có (chi tiết ở PHẦN M); bản thiết bị thật còn chờ.
- ☐ **Killer experiment đầy đủ** (B0 vs B3 trên app A), B3 $n \geq 300$: kiểm 3 điều kiện (a)(b)(c).
- ☐ Ma trận T1 (~8.000 trial LLM) trên emulator/Cuttlefish; đo độ trễ/bộ nhớ trên Pixel thật.
- ☐ Họ tấn công kịch bản (3, 4, TOCTOU của 7) với $n \geq 10^4$, không LLM.
- ☐ Ghi **mọi** loại trừ theo nhóm (agent crash, platform crash, network outage, user cancel, định danh không hỗ trợ); chặn trước chính sách outlier.
- ☐ Xuất raw secret-free: `trials.jsonl`, `summary.json`, `metrics.csv`, `provenance.json` mở rộng (hash git/AOSP/build/kernel/APK/model/prompt/policy).
- ☐ Sinh bảng/hình **chỉ** từ raw.
- ☐ **DoD:** (a) giá trị thô vắng mọi artifact; (b) redirect bị từ chối; (c) login hợp lệ thành công; mọi loại trừ được ghi; bảng/hình sinh từ raw.

PHẦN J — Giai đoạn 8–9: Mở rộng T2/T3 (chỉ khi G2 qua)

- ☐ (T2) Adapter clipboard nhạy cảm: thay nội dung clip hướng tác nhân bằng projection công khai; giữ dán thường cho người dùng.
- ☐ (T2) App C (địa chỉ + điện thoại); B2 + so sánh cơ chế che nền tảng.
- ☐ (T2) Đo năng lượng (Perfetto/Batterystats); tác nhân thứ hai; hồi quy tác vụ chung.
- ☐ (T2) WebView fail-closed: đo tỉ lệ từ chối sai, ghi `unsupported`.
- ☐ (T3) Credential Manager adapter; ví + Protected Confirmation (app D).
- ☐ (T3) Xác thực WebView origin (node→frame→origin); fail-closed nếu không đủ.
- ☐ (T3) Kho bền vững + nhật ký sự cố + đa người dùng/sao lưu; khóa StrongBox/Knox; thiết bị OEM.
- ☐ Lưu ý: hạng mục T3 **không** nêu trong đóng góp nếu chưa làm — chuyển sang Giới hạn/Hướng phát triển.

PHẦN K — Giai đoạn 10: Phân tích & viết bài (W9–W15)

- ☐ Rút gọn bản thảo 53 trang về giới hạn venue (~12–13 trang thân bài; xác nhận CFP); chuyển chứng minh/thí nghiệm bổ sung sang phụ lục/technical report.
- ☐ Báo cáo nhị phân dạng "0 of n" + Wilson CI; không tuyên bố tuyệt đối từ zero.
- ☐ Độ trễ: trung vị, phân vị đuôi, bootstrap interval (theo cụm), phân phối đầy đủ.
- ☐ So sánh cặp: McNemar chính xác / permutation cặp; RQ1–RQ4 là primary.
- ☐ Thay **mọi** gạch/TODO trong bảng kết quả/tham số/ablation/tương thích bằng giá trị đo/`unsupported`/`not applicable`.
- ☐ Thay/gỡ tọa độ PGFPlots khái niệm (`figures/pgfplots_placeholder_results.tex`).

- ☐ Kiểm giả định định lý bằng oracle thực nghiệm; nêu giả định nào còn kiến trúc.
- ☐ Cập nhật closest-work/novelty; chạy lại tìm kiếm tài liệu ngay trước nộp; xác minh toàn văn các so sánh mới.
- ☐ Chuyển sang class/mẫu LaTeX của venue; điền metadata tác giả/cơ quan/tuyên bố lợi ích/dữ liệu/đạo đức; tuân chính sách ẩn danh/đạo đức/AI-LLM.
- ☐ **DoD (bản full):** không còn TODO/gạch trong bảng; mọi hình/bảng tái tạo từ raw; metadata cuối điền; checker nộp xanh.
- ☐ **Mốc bản full: đóng băng số liệu + bản thảo** (lịch kỳ sau).

PHẦN L — Trích dẫn & bằng chứng

- ■ Nâng so sánh chỉ-abstract trong `citation_claim_map.csv` lên xác minh full-text trang/mục (đặc biệt vai trò AutoDroid; bằng chứng thực tế ở `sections/`). **2026-10-17:** closest-work `zhao2026anonymization` đã xác minh full-text (arXiv HTML v3, Sec. 3.2/3.5); **sửa lỗi** `wen2023autodroid` — nay chỉ trích dẫn đúng vai trò hệ tác nhân di động; đã sửa ở cả `mobisys/` và bản full. **Bổ sung 2026-10-17:** 4 mục còn lại đã đối chiếu bản arXiv hiện hành — `du2025mobileattacks` nâng lên **full-text** (arXiv HTML v3, Sec. IV-C: thu hoạch mã xác minh Alipay); `debenedetti2025camel` (v2), `costa2025fides` (v2), `shi2025progent` (v3) giữ **abstract verified** vì bản thảo chỉ dùng tóm tắt cấp cao đã được bao hàm; đã ghi nhận trôi phiên bản. Quyết định mở: **đã chốt 2026-10-22** — tiêu đề bib cho `du2025mobileattacks` dùng tiêu đề bản **v3** (*Exploiting Mobile LLM Agents as Confused Deputies via Non-App-Controlled Channels*) vì bản thảo trích v3 (nội dung đã xác minh ở Sec. IV-C); metadata arXiv chưa phản ánh — rà lại ở camera-ready trong trường hợp metadata cập nhật. Đã sửa `references_verified.bib` + `citation_claim_map.csv` + `citation_todo.md` + `citation_consistency_report.md`.
- ☐ Chạy lại tìm kiếm tài liệu ngay trước nộp; cập nhật closest-work/novelty.
- ☐ Thay arXiv bằng bản archival khi có; xác minh tác giả/trang/DOI/venue.
- ☐ Giải quyết trích dẫn archival ổn định cho DroidRun nếu dùng làm tác nhân đánh giá.
- ☐ Giữ HaS, Rescriber, PAPILLON, PrivacyRestore, Dual-LLM pattern, trang sự kiện/sản phẩm ở ngoài trừ khi xác minh bản ghi/claim chính.
- ☐ Archive snapshot các trang Android Developers/AOSP dùng trích dẫn (kèm access date).

PHẦN M — Artifact & nộp bài (W15–W16, Giai đoạn 11)

- ⊡ Phát hành: patch set AOSP, build manifest, hash app/tác nhân/mô hình, prompt, seed, canary monitor, schema raw-data, script phân tích, license. **Đã có:** seed ghim trong cấu hình, canary monitor, schema, script phân tích/kiểm; **2026-10-22:** giấy phép đã chốt — `Apache-2.0`, holder "SecretHandle Authors" (khớp AOSP, cấp bằng sáng chế); đã cài `SecretHandle/LICENSE`, ghi vào `pyproject.toml`, `docs/artifact.md`, §artifact bản mobisys. **Còn:** patch set AOSP/build manifest chờ build thiết bị.
- ■ Phụ lục artifact + mô tả (MobiSys artifact evaluation *tùy chọn*, sau khi được nhận); tách test thiết bị khỏi test emulator; tài liệu tính năng OEM không có. **2026-10-17:** viết `docs/artifact.md` (mô tả artifact, lệnh một-bước, smoke offline, phạm vi, ghi chú LICENSE) và `docs/oem_features.md` (tính năng OEM thiếu + tầng test). Tách tầng test bằng marker pytest `device`/`emulator` (`pyproject.toml`) + target `make test-offline` + mục "Test tiers" trong `docs/reproducibility.md`. Phụ lục chính thức trong bài nộp để sau khi được nhận.
- ■ Một lệnh build/run + smoke test canary cô lập offline; CI Python 3.11/3.12 + pipeline thiết bị kích hoạt thủ công. `make check`/`scripts/smoke_check.py` (offline, 1599 canary, 0 rò rỉ); `.github/workflows/ci.yml` (3.11/3.12) + `device.yml` (`workflow_dispatch`); local verify 74 passed (2026-10-17).
- ⊡ Rà `TODO_before_submission.md` lần cuối; chạy checker LaTeX, kiểm accessibility, plagiarism/self-overlap, camera-ready. **2026-10-17:** thêm `tools/manuscript_check.py` (quét placeholder + build + parse log) và `tools/self_overlap.py` + `self_overlap_report.md` (trùng lặp nội bộ short vs full:

3.2% 15-gram); `accessibility_audit.md` (posture; `accessibility.sty` chưa cài nên `\Description` tạm hoãn). build mobisys sạch (0 undefined/0 overfull); `sections/`+`appendix/` không còn placeholder. **Còn:** camera-ready validation (sau khi được nhận).

- ⊡ Render lại mọi hình/bảng sau thay đổi class cuối; lặp `figure_quality_audit.md`. **2026-10-17:** render lại 6 hình bản full (trang 11/13/17/21/30/34) + hình mobisys (trang 4) vào `figure_previews/`; cập nhật audit (nguồn hình không đổi từ 2026-10-03, chỉ dịch trang). **Còn:** lần render/soát cuối sau khi chốt class + soát mắt hình mobisys mới.
- ☐ Nộp **trước** hạn vài ngày (hạn kỳ sau — tra cứu CFP tại thời điểm lập lịch).

PHẦN N — Audit bảo trì (chạy lại sau mỗi thay đổi lớn)

- ☐ `math_audit.md` + `theorem_dependency_graph.md` sau đổi định lý.
- ☐ `notation_consistency_check.md` sau đổi ký hiệu.
- ☐ `citation_consistency_report.md` + `citation_claim_map.csv` sau đổi trích dẫn.
- ☐ `figure_quality_audit.md` sau render lại hình.
- ☐ `claim_strength_audit.md` sau đổi tuyên bố.
- ☐ `topic_alignment_check.md` + `idea_fidelity_report.md` sau đổi phạm vi/đóng góp.
- ☐ `SecretHandle/audits/*` sau mỗi thay đổi ngữ nghĩa mã.
- ☐ `reviewer_audit.md` sau mỗi vòng soát.

LỘ TRÌNH THỰC NGHIỆM BẢN FULL (FULL RESEARCH PAPER ROADMAP)

Mục tiêu: Bổ sung đầy đủ 6 hạng mục thực nghiệm empirical trên Android Emulator / Thiết bị thật để trả lời hoàn chỉnh 6 câu hỏi nghiên cứu (RQ1–RQ6) phục vụ bản Full Paper.

- ⊡ **Hạng mục 1: Tấn công Đọc & Lộ OTP (Attack 1 — Read & Exfiltrate OTP) [RQ1, RQ4]**
  - ■ Tái hiện B_0 (Unprotected) trên Android Emulator ($n = 30$ trials, $29/30$ rò rỉ, Wilson $[0.833, 0.994]$).
  - ■ Đo nguyên mẫu B_3 (SecretHandle Prototype) trên Android Emulator ($n = 30$ trials, $0/30$ rò rỉ, Wilson $[0.000, 0.114]$).
  - ☐ Đo đối chứng bổ sung với mô hình LLM khác (Claude 3.5 Haiku, GPT-4o) để chứng minh tính bất biến theo model.
- ☐ **Hạng mục 2: Thí nghiệm then chốt: Chống chuyển hướng độc hại (Attack 2 — Destination Redirection / Killer Experiment) [RQ2]**
  - ☐ Dựng ứng dụng độc hại (Attacker Receiver App / Malicious Intent Destination) trên emulator.
  - ☐ Kích hoạt Agent nhận handle `SH-XXXXXX` và cố tình điền vào ô input của app độc hại.
  - ☐ Thu thập log chứng minh: SecretHandle Resolver xác thực UID/Package/TaskToken và từ chối giải mã (`Reject`, an toàn 100%).
  - ☐ Ngược lại: Khi điền vào app hợp lệ (Legitimate App) → giải mã thành công 100%.
- ☐ **Hạng mục 3: So sánh đối đầu với Baseline B_1 (Detected Placeholder / Anonymizer) [RQ2]**
  - ☐ Cài đặt baseline B_1: Che số OTP bằng regex/LLM placeholder nhưng KHÔNG có ràng buộc đích (destination binding).
  - ☐ Chạy kịch bản Attack 2 đối đầu B_1: Chứng minh B_1 bị lừa chuyển hướng (redirection leakage $= 1.0$), trong khi B_3 (SecretHandle) giữ vững $= 0.0$.
- ☐ **Hạng mục 4: Kiểm tra vòng đời & Chống Replay (Attack 4 — Replay, Concurrency & Expiry) [RQ3]**
  - ☐ Kiểm tra Replay: Tái sử dụng cùng một handle `SH-XXXXXX` lần thứ hai → Resolver từ chối với lỗi `ALREADY_RESOLVED`.

- ☐ Kiểm tra Expiry: Giải mã sau khi hết hạn TTL (5 phút) → Resolver từ chối với lỗi `HANDLE_EXPIRED`.
- ☐ Kiểm tra Race condition: Gửi đồng thời hai yêu cầu resolve song song → chỉ đúng một yêu cầu được chấp nhận.

☐ **Hạng mục 5: Đo đạc hiệu năng & độ trễ (Overhead Benchmark — RQ5)**

- ☐ Microbenchmark độ trễ (100 lần lặp, ghi nhận mean, median, 95th-percentile ms):
  - Thời gian tạo handle (`Mint latency`).
  - Thời gian giải mã (`Resolve latency`).
  - Thời gian phủ overlay (`Redact latency`).
- ☐ Đo đạc tài nguyên: Mức tiêu thụ bộ nhớ RAM (MB) và CPU overhead của tiến trình SecretHandle.

☐ **Hạng mục 6: Đa dạng hóa Ứng dụng & Hồi quy tác vụ chung (Workloads & Benign Regression) [RQ6]**

- ☐ Workload B: Đăng nhập 2FA nhiều bước với tin nhắn đối kháng preview.
- ☐ Workload C: Điền thông tin cá nhân/địa chỉ (Checkout form).
- ☐ AndroidWorld Benign Regression: Chạy các tác vụ thông thường của AndroidWorld (không có OTP) để đo độ ảnh hưởng của SecretHandle đến năng lực điều khiển của Agent (chứng minh regression $\approx 0\%$).

Rủi ro chính & phương án

Rủi ro	Phương án
Thiếu thiết bị thật Pixel	Chạy toàn bộ ma trận tấn công trên Android Emulator (máy chủ EC2 có KVM) với Android 14 API 33/34; ghi rõ phạm vi trong Methodology.
Thời gian chạy LLM lâu	Dùng Bedrock bearer token trực tiếp qua bridge cục bộ; tự động hóa batch chạy ban đêm trên EC2.
Kẻ tấn công bypass lớp phủ screenshot	SecretHandle kết hợp cả chặn notification và che phủ overlay; trên bản full kết hợp thêm `system_server` private input.

5 hành động tiếp theo (ưu tiên ngay)

1. ■ **Hoàn thành $n = 30$ trials cho Attack 1** (B_0 vs B_3 trên EC2, Wilson CI [0.83, 0.99] vs [0, 0.114]).
2. ☐ **Triển khai Attack 2 (Destination Redirection)**: Thiết lập kịch bản agent cố giải mã handle vào app độc hại trên EC2 → chứng minh Resolver chặn 100%.
3. ☐ **Chạy Microbenchmark đo độ trễ & RAM (RQ5)**: Thu thập số đo mili-giây cho Mint, Resolve, Redact để lấp đầy bảng kết quả hiệu năng.
4. ☐ **Đo đối đầu với Baseline B_1**: Chứng minh các giải pháp che giấu không ràng buộc đích đều thất bại trước Attack 2.
5. ☐ **Tự động hóa kịch bản test Replay & Expiry (Attack 4)**: Đo 100 lần thử lặp lại handle và kiểm tra cơ chế thu hồi.

Ghi chú: Khi một mục xong, đổi ☐ → ■ và ghi ngày. Biên dịch: `xelatex MASTER_CHECKLIST.tex` hai lần.